



National Geospatial-Intelligence Agency

INSTRUCTION

NUMBER 8010.14

30 August 2017

Administrative Update 1, 28 July 2020

CIO-T

SUBJECT: Password Management

References: See Enclosure 1.

1. PURPOSE. This Instruction:

a. Establishes policy, assigns responsibilities, and provides procedures for NGA information system password management.

b. Rescinds NGA Instruction 8010.14, "NGA Instruction for Password Administration," September 2008.

2. APPLICABILITY. This Instruction applies to all NGA civilian employees, military service members, other Government agency personnel assigned to NGA, and contractors, hereinafter referred to as personnel.

3. DEFINITIONS. See Glossary.

4. POLICY. It is NGA policy to:

a. Perform password management in accordance with (IAW) References (a) through (i).

b. Configure information system passwords IAW References (b), (f), and (i).

c. Store encrypted passwords in authorized information systems using NGA-approved password management tools. The tools must be compliant with the Intelligence Community and NGA policies and approved through the Software White List Approval Process prior to use IAW Reference (k).

1) Do not store passwords on paper or non-NGA approved electronic methods (e.g., Microsoft Word, Excel or Notepad) whether or not the passwords are encrypted IAW Reference (k).

2) If passwords must be written down due to continuity purposes, place the password in a sealed envelope and stored in an approved safe and room authorized for storage at the same or higher classification level as the password IAW Reference (k).

5. RESPONSIBILITIES. See Enclosure 2.

6. PROCEDURES. See Enclosure 3.

7. EFFECTIVE DATE. This Instruction is effective on the date of signature.

A handwritten signature in purple ink, appearing to read 'Tanya Pemberton', with a long horizontal flourish extending to the right.

Tanya Pemberton
Chief Information Officer

Enclosures

1. References
2. Responsibilities
3. Procedures

Glossary

CHANGE LOG

Change	Change Date	Revised By	Page(s) Affected	Change Description
1	28 July 2020	DXCI	1, 2	Added password information from ref (k)
1	28 July 2020	DXCI	4	Updated references
1	28 July 2020	DXCI	6	Added <i>and this instruction</i> to item 8
1	28 Jul 2020	DXCI	7	Removed section clarifying password storage (moved to pg. 1 and 2)

ENCLOSURE 1REFERENCES

- (a) National Institute of Standards and Technology (NIST) Special Publication (SP) 800-37, "~~Guide for Applying the Risk Management Framework to Federal Information Systems~~ RMF for Information Systems and Orgs: A System Life Cycle Approach for Security and Privacy," Revision ~~12, February 2010~~ **1 December 2018**
- (b) NIST SP 800-53, Revision 4, "Security and Privacy Controls for Federal Information Systems and Organizations," ~~April 2013~~ **2015**
- (c) Committee on National Security Systems Instruction (CNSSI) 4009, "National Information Assurance Glossary," 06 April 2015
- (d) Department of Defense (DoD) Directive 8500.01, "Cybersecurity," 14 March 2014 **change 1, 07 October 2019**
- (e) Intelligence Community (IC) Directive 503, "Intelligence Community Information Technology Systems Security Risk Management," 21 July 2015
- (f) IC Standard 500-16, "Password Management," 16 March 2011
- (g) NGA Directive (NGAD) 8000, "Information Management and the Chief Information Officer," 12 June 2013, **Admin Update 2, 28 October 2015**
- (h) NGAD 8010, "Information Systems Risk Management Framework (RMF)," 27 August 2015, **Admin Update 1, 16 November 2015**
- (i) NGA Information Assurance Requirements Catalog (IARC), ~~16 May 2016~~ **Current Edition**, (<https://ngaonline/sites/CIO-T/TS/TSR/Pages/Informational-Documents.aspx>)
- (j) Geospatial Intelligence (GEOINT) Annex: "National Geospatial-Intelligence Agency (NGA) Cyber Operations Security Classification Guide (SCG)," 06 June 2016
- (k) **Chief Information Security Officer Memorandum For Record, U-2020-00000, "Password Storage," March 10, 2020**

ENCLOSURE 2

RESPONSIBILITIES

1. Director, NGA (D/NGA).

a. Designates the Chief Information Officer (CIO) as the primary Authorizing Official (AO).

b. Designates the Chief Information Security Officer (CISO) and Deputy CISO (D/CISO) in the CIO-T/Chief of Information Security (TS), Cybersecurity Office, as additional AOs IAW References (e) and (h).

2. CIO, CISO, and D/CISO.

a. Perform as NGA AOs, and make authorization decisions for information systems on behalf of the D/NGA.

b. Assume responsibility for operating information systems at an acceptable level of risk IAW Reference (e).

c. Approve requests for waivers from the requirements of this Instruction.

3. Director, CIO-T Secure Operations Group, Operations Control Office (D/CIO-T/TOC), performs and oversees initial password assignments for users, system administrators (SAs), and privileged users.

4. Component Directors and Agency Element (AE) Leads ensure their appointed information system owners/program managers assigned to information systems perform password management requirements IAW References (b), (f), (h), and (i) and this Instruction.

5. Information System Owners/Program Managers.

a. Ensure password management requirements are implemented and adhered to on all NGA information systems under their control IAW References (b), (f), (h), and (i) and this Instruction.

b. Develop, publish, and implement password management processes and procedures for information systems under their control IAW References (b), (f), (h), and (i) and this Instruction.

c. Submit information system password waivers to the AO for review and adjudication IAW this Instruction.

d. Appoint SAs to execute and maintain system password requirements IAW References (b), (f), (h), and (i) and this Instruction.

6. SAs support their information system owner/program manager by executing information system password management activities IAW Reference (i). SAs may develop procedures specifically for the information systems they support.

7. Privileged Users (e.g., vulnerability management team members who use elevated system privileges, data transfer officers, etc.) comply with information system password requirements IAW Reference (i) and this Instruction.

8. Personnel comply with the password requirements IAW Reference (i) **and this instruction.**

ENCLOSURE 3PROCEDURES

1. Default Passwords. Before formal security control assessment and prior to placing an information system into operational service, SAs must replace all standard and default vendor passwords with properly configured passwords IAW Reference (i).
2. Password Assignment. Users, SAs, and privileged users contact the Enterprise Service Center (ESC) Helpdesk to obtain an initial password. Users, SAs, and privileged users immediately change their initial password at first login. The ESC develops and manages their own standard operating procedures that include the specific details of this process.
3. Password Characteristics. Users, SAs, and privileged users create strong passwords following the guidance in Reference (i), *"Identification and Authentication (IA), Password Based Authentication,"* Security Control IA-5. SAs configure the information system to enforce all password complexity requirements IAW this Instruction and Reference (i).
4. Classification and Safeguarding Passwords. Passwords are classified and safeguarded commensurate with the highest level of classification and sensitivity of the information protected by the password IAW Reference (j). ~~Users, SAs, and privileged users do not record passwords on any medium. If passwords must be written down for continuity purposes, the written password is placed in a sealed envelope and stored in an approved safe and room authorized for storage at the appropriate classification level.~~
5. User Lockouts. SAs configure information systems to automatically lock user accounts after the threshold for invalid login attempts is reached IAW Reference (i), *"Access Control (AC) Unsuccessful Login Attempts,"* Security Control AC-7. Account access is restored upon satisfaction of the criteria IAW Reference (i), Security Control AC-7.
6. Password Change Authorization. Users, SAs, and privileged users change their passwords when prompted by the information system. Passwords are changed within timeframes specified IAW Reference (i), *"IA Management,"* Security Control IA-5. Users, SAs, and privileged users are only permitted to change their own passwords. The information system is configured to allow the number of password generations specified in Reference (i), Security Control IA-5.
7. Shared or Group Passwords. Shared or group passwords are not authorized unless approved by the AO. The information system owner and/or program manager documents the shared or group password requirement in a justification request and provides the request and a password management concept of operations to the AO for review. Upon a favorable review, the AO approves the justification request and provides the approval to the information system owner/program manager. Upon receiving the AO

approval, the information system owner and/or program manager updates the impacted information system security plan required by Reference (b).

8. Passwords Associated with Privileged User Accounts. Privileged user accounts and associated passwords are restricted to SAs and specific individuals who perform system maintenance, administration, or vulnerability assessments. Each information system owner/program manager performs a quarterly validation of all personnel assigned privileged user accounts IAW Reference (i). The information system owner/program manager then provides a written quarterly validation report to the AO and CISO at the periodicity specified in Reference (i), *“AC Account Management,”* Security Control AC-2 and *“AC Least Privilege,”* Security Control AC-6.

9. Disabling Access. Access to the information system is disabled for the following reasons: reassignment of responsibilities as an SA or privileged user, transfer from NGA to another organization, retirement, loss of access, loss of security clearance, or inactivity IAW Reference (i), *“IA Identifier Management,”* Security Control IA-4. As appropriate for the situation, the user’s functional manager, the Security and Installations Directorate, Office of Personnel Security, or the information system owner/program manager will notify the ESC Helpdesk and, as required, the impacted information system SA to disable the affected users access/password.

10. Waiver Requests. The information system owner/program manager may submit a waiver request for consideration for an exemption of the password requirements of this Instruction. The information system owner/program manager submits password waiver requests electronically directly to the AO. The AO reviews the waiver request and upon a favorable review, provides the approval to the information system owner/program manager. Upon receiving the AO approval, the information system owner/program manager updates this information within the impacted information system security plan required by Reference (b).

GLOSSARY

Authorizing Official (AO)	A senior (Federal) official or executive with the authority to formally assume responsibility for operating an information system at an acceptable level of risk to organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, and the Nation. (Reference (c))
Chief Information Officer (CIO)	Agency official responsible for: (1) providing advice and other assistance to the head of the agency and other senior management personnel to ensure that information systems are acquired and information resources are managed in a manner that is consistent with laws, Executive Orders, directives, policies, and regulations; (2) developing, maintaining, and facilitating the implementation of a sound and integrated information system architecture for the agency; and (3) promoting the effective and efficient design and operation of all major information resources management processes for the agency, including improvements to work processes of the agency. (Reference (c))
Chief Information Security Officer (CISO)	Official responsible for carrying out CIO responsibilities under the Federal Information Security Management Act and serving as the CIO's primary liaison to the agency's authorizing officials, information system owners, and information systems security officers. Also known as Senior Agency Information Security Officer. (Reference (c))
Information System	A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. (Reference (c))
Information System Owner (or Program Manager)	Official responsible for the procurement, development, integration, modification, operation, maintenance, and disposal of an information system. (Reference (a))
Password	A protected, private string of letters, numbers, and/or special characters used to authenticate an identity or to authorize access to data. (Reference (c))
Privileged User	A user authorized (and therefore trusted) to perform security-relevant functions that ordinary users are not allowed to perform. (Reference (c))
Security Plan	Formal document that provides an overview of the security requirements for an information system or an information security

program and describes the security controls in place or planned for meeting those requirements. (Reference (c))

System Administrator (SA)	Individual responsible for the installation and maintenance of an information system, providing effective information system utilization, adequate security parameters, and sound implementation of established information assurance policy and procedures. (Reference (c))
User	Individual or system process acting on behalf of an individual, authorized to access an information system. (Reference (c))